

Risk ID	Risk Statement	Treatment Option
R01	Weak or inconsistently governed access could allow unauthorized access to customer or transaction information, causing confidentiality breach, fraud exposure and loss of trust.	Mitigate
R02	Irregular security awareness may enable phishing or social engineering, resulting in credential compromise and unauthorized system access.	Mitigate
R03	Inconsistent supplier security checks may allow a vulnerable or poorly controlled third party to compromise NovaPay information or services.	Mitigate / Share
R04	Without a formal asset inventory, critical assets may be unmanaged, unowned or incorrectly protected, increasing the likelihood of loss or exposure.	Mitigate
R05	Inadequate secure-development governance may introduce exploitable defects or unauthorized code changes into the payment service.	Mitigate
R06	Unmanaged cloud configuration or access could expose services/data or cause disruption.	Mitigate
R07	Technical vulnerabilities may remain exploitable if identification and remediation are not governed consistently.	Mitigate
R08	Insufficient logging or monitoring could delay detection of account misuse, attacks or transaction-related anomalies.	Mitigate
R09	Reactive security decision-making may lead to inconsistent incident assessment, escalation, containment and lessons learned.	Mitigate
R10	A technology, supplier or cyber disruption could make digital payment services unavailable and materially affect customers and operations.	Mitigate / Share
R11	Failure to identify and meet applicable privacy, legal or contractual requirements could cause regulatory, contractual and reputational harm.	Mitigate
R12	Excessive privileged or repository access could allow unauthorized disclosure or alteration of source code and production-related configurations.	Mitigate

Planned Action

Implement role-based access, identity lifecycle controls, secure authentication/MFA, periodic access reviews and security logging.

Formalize awareness training, phishing education, event reporting and strong authentication.

Tier suppliers by risk; perform due diligence; include security clauses; monitor critical suppliers and cloud services.

Create asset inventory; assign owners; classify information; define acceptable-use and lifecycle requirements.

Establish secure SDLC, application security requirements, secure coding, security testing and controlled changes.

Establish cloud security responsibilities, configuration baselines, access controls and periodic review.

Implement vulnerability scanning, risk-based remediation SLAs, exception handling and tracking.

Define logging standards, centralize security-relevant logs, alert on priority events and review monitoring effectiveness.

Document incident roles, severity criteria, response procedures, evidence handling and lessons learned; run a tabletop exercise.

Complete business impact analysis; define recovery objectives; test backups, continuity and supplier dependencies.

Create and maintain an Irish/EU legal and regulatory obligations register; map applicable GDPR/privacy requirements to controls; retain evidence and review compliance periodically.

Restrict privileged and source-code access; review entitlements; protect repositories; log administrative actions.

Proposed Owner	Priority	Target Timeline	Target Likelihood
IT/Security + Business Owners	Critical	Months 2-4	2
GRC/HR + IT	Critical	Months 2-3	2
GRC/Procurement/IT	Critical	Months 2-4	2
IT/GRC + Asset Owners	High	Weeks 2-6	2
Engineering + Security	Critical	Months 2-4	2
Cloud/IT + Security	High	Months 2-4	2
IT/Security	High	Months 2-4	2
Security/IT	High	Months 2-4	2
Security/GRC/Management	High	Months 2-5	2
Operations/IT/Management	Critical	Months 3-5	2
GRC/Legal/Management	Critical	Months 2-5	2
Engineering/IT/Security	High	Months 2-4	1

Target Impact	Status	Validation / Acceptance Note	Target Residual Score
	5 Open	Pending validation after implementation and control testing.	10
	4 Open	Pending validation after implementation and control testing.	8
	5 Open	Pending validation after implementation and control testing.	10
	4 Open	Pending validation after implementation and control testing.	8
	5 Open	Pending validation after implementation and control testing.	10
	4 Open	Pending validation after implementation and control testing.	8
	4 Open	Pending validation after implementation and control testing.	8
	4 Open	Pending validation after implementation and control testing.	8
	4 Open	Pending validation after implementation and control testing.	8
	5 Open	Pending validation after implementation and control testing.	10
	5 Open	Pending validation after implementation and control testing.	10
	5 Open	Pending validation after implementation and control testing.	5

Target Residual
Ratio

High

Moderate

High

Moderate

High

Moderate

Moderate

Moderate

Moderate

High

High

Moderate